COMPTIA SECURITY+ SY0-701 DOMÍNIO 1 · CONCEITOS GERAIS DE SEGURANÇA (12%)

Security+ 1.2 · Non-repudiation

Mestre CyberSec · **Aula 1.2 — Non-repudiation** (7:57) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Não-repúdio: prova irrefutável de QUEM fez — impossível negar depois. Implementação: hash do dado cifrado com a chave PRIVADA de quem assina (assinatura digital). Qualquer um valida com a pública. Base de contrato digital, transação, log de auditoria.

💡 Highlights que a prova CompTIA cobra

- Hash só prova integridade; assinatura prova integridade + AUTOR
- Assimétrico: privada assina, pública valida
- Prova de não-Repúdio: 'não foi eu' é impossível de alegar após assinado

🎯 Dicas de Prova & Cenários Típicos da Banca

- Se a questão cita 'cannot deny'/'cannot dispute' = non-repudiation
- Qual algoritmo: RSA assinatura (não AES — AES é simétrico, sem autor único)

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 1.2 — Non-repudiation)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Não-repúdio (N/A)

Objetivo de segurança que garante que uma parte não possa negar ter realizado uma ação, como assinar uma mensagem ou aprovar uma transação. Fornece prova irrefutável de origem ou autoria.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'cannot deny', 'cannot dispute', 'prova de autoria'. Não confunda com integridade: hash sozinho não dá não-repúdio.*

• Assinatura Digital (N/A)

Técnica criptográfica que gera um hash dos dados e cifra/assina o hash com a chave privada do remetente. Prova integridade mais origem/autenticação e fornece não-repúdio.

⚠️ ***Armadilha CompTIA:*** *Assinatura digital = integridade + autor. Se a questão pedir 'não-repúdio', a resposta normalmente é assinatura digital, não apenas hash.*

• Hash (Função de Hash) (N/A)

Função unidirecional que produz um resumo de tamanho fixo a partir de dados; verifica integridade ao detectar alterações. Sozinho, não prova quem criou ou enviou os dados.

⚠️ ***Armadilha CompTIA:*** *Hash = integridade apenas. Se a questão exige autor/não-repúdio, precisa de assinatura digital, não só hash.*

• Criptografia Assimétrica (N/A)

Criptografia que usa um par de chaves: uma pública e uma privada. Para não-repúdio, o assinante usa a chave privada e os verificadores usam a chave pública correspondente.

⚠️ ***Armadilha CompTIA:*** *Assimétrico: privada assina, pública valida. Não use AES para assinatura/não-repúdio; AES é simétrico e não identifica autor único.*

• Chave Privada (N/A)

A chave secreta em um par assimétrico, conhecida apenas pelo proprietário. Cria assinaturas digitais e decifra dados cifrados com a chave pública correspondente.

⚠️ ***Armadilha CompTIA:*** *Privada do signatário assina; nunca é compartilhada. Se a privada não for exclusiva, a alegação 'não foi eu' pode ser possível.*

• Chave Pública (N/A)

A chave distribuível livremente em um par assimétrico. Verifica assinaturas digitais e cifra dados para o detentor da chave privada correspondente.

⚠️ ***Armadilha CompTIA:*** *Pública valida assinatura; não dá não-repúdio se usada para assinar, pois não é exclusiva do autor. Confirme sempre privada assina / pública valida.*

• RSA

Algoritmo criptográfico assimétrico comumente usado para assinaturas digitais e troca de chaves. Em questões de não-repúdio do Security+, assinaturas RSA provam autoria via assinatura com chave privada e verificação com pública.

⚠️ ***Armadilha CompTIA:*** *Se pedir algoritmo para assinatura/não-repúdio, pense RSA/ECDSA/DSA (assimétricos). AES é simétrico e não prova autor único.*

• Integridade (N/A)

Objetivo de segurança que garante que os dados não foram alterados ou adulterados. Hash prova integridade, mas não-repúdio exige também prova do autor.

⚠️ ***Armadilha CompTIA:*** *Integridade não é não-repúdio. Se a pergunta diz 'cannot deny', não basta hash/checksum; precisa de assinatura digital.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 O Conceito de Não-repúdio: A Prova Jurídica de Autoria

🏠 **Analogia Intuitiva:** Uma escritura de compra e venda de imóvel assinada presencialmente no cartório de notas, com reconhecimento de firma por autenticidade, impressão digital e gravação do ato em livro público. O vendedor jamais poderá ir à justiça alegar: 'Não fui eu quem vendi essa casa, foi um estranho que inventou meu nome'.

🔍 **Causa Raiz / Por que foi criado:** Se um sistema utilizar apenas senhas simples ou chaves simétricas compartilhadas, qualquer usuário mal-intencionado que cometer uma fraude financeira poderá alegar negação plausível ('outro colega descobriu minha senha' ou 'o administrador do banco alterou o banco de dados'). O não-repúdio elimina a possibilidade de negação.

🛡️ **Visão do Auditor de GRC:** Em auditorias regulatórias (SOX 404, HIPAA, normas bancárias do Banco Central / SEC), o auditor verifica se aprovações de ordens de pagamento, alterações em código-fonte e contratos eletrônicos possuem validade probatória irrefutável com identificação inequívoca do autor.

⚠️ **Como cai na Prova CompTIA:** Palavras-chave que entregam a questão: 'Cannot deny having performed the action', 'Cannot dispute having sent the message', 'Proof of origin and authorship'. Resposta certa da CompTIA: Non-repudiation garantido por Digital Signatures.

📌 Assinatura Digital e a Criptografia Assimétrica

🏠 **Analogia Intuitiva:** O anel de sinete exclusivo do imperador cravado em cera quente sobre uma ordem oficial. Todos os generais do exército possuem uma gravura oficial do brasão imperial (Chave Pública) para conferir se a marca é legítima, mas somente o imperador carrega o anel de sinete físico no dedo (Chave Privada) capaz de estampar a marca na cera.

🔍 **Causa Raiz / Por que foi criado:** A criptografia simétrica (como AES) compartilha a mesma chave secreta entre emissor e receptor, o que significa que o receptor também poderia ter forjado a mensagem. Para garantir autoria única, a chave que assina deve pertencer exclusivamente a um único indivíduo.

🛡️ **Visão do Auditor de GRC:** O auditor de PKI inspeciona a governança do ciclo de vida das chaves privadas: verifica se chaves de assinatura de certificados e autoridades certificadoras (CA) estão trancadas em módulos de segurança em hardware (HSM FIPS 140-2/3) e se listas de revogação de certificados (CRL) e protocolos OCSP estão ativos.

⚠️ **Como cai na Prova CompTIA:** Fórmula matemática sagrada da CompTIA: O remetente assina cifrando o hash do documento com a SUA PRÓPRIA CHAVE PRIVADA. O destinatário verifica decifrando a assinatura com a CHAVE PÚBLICA DO REMETENTE. CUIDADO com o distrator: cifrar com a pública do destinatário garante Confidencialidade, NÃO não-repúdio!

📌 Carimbo de Data/Hora Seguro (Secure Timestamping - RFC 3161)

🏠 **Analogia Intuitiva:** Uma foto de prova de vida segurando o jornal do dia impresso, ou o protocolo mecânico autenticado com relógio de ponto atômico lacrado de um cartório. Não basta provar que foi você quem assinou o cheque; é indispensável provar que assinou às 14h de terça-feira, antes de a conta ter sido bloqueada judicialmente.

🔍 **Causa Raiz / Por que foi criado:** Se um certificado digital expirar ou for revogado anos depois por suspeita de vazamento de chave, o fraudador poderia alegar que um contrato assinado legitimamente no passado foi forjado após a chave ter expirado. O carimbo seguro de uma Time Stamping Authority (TSA) prova o instante exato da assinatura.

🛡️ **Visão do Auditor de GRC:** O auditor verifica a sincronização de relógios dos servidores via NTP autenticado e o uso de autoridades carimbadoras de tempo credenciadas (TSA) em sistemas de arquivo de documentos digitais de longo prazo (normas ICP-Brasil, eIDAS ou PAdES/XAdES).

> ⚠️ **Como cai na Prova CompTIA:** Gatilho do exame: 'Prove that a signed transaction occurred before the signing certificate was revoked or expired'. Resposta da prova: Secure Timestamping / Time Stamping Authority (TSA).

📌 Trilhas de Auditoria Imutáveis e Armazenamento WORM

🏠 **Analogia Intuitiva:** Gravar leis em uma tábua de pedra com cinzel ou queimar dados fiscais em um disco CD-R ótico não regravável. Uma vez que o raio laser queima os sulcos no plástico do disco, ninguém no planeta — nem mesmo o dono do computador ou o presidente da empresa — consegue alterar ou apagar uma única vírgula.

🔍 **Causa Raiz / Por que foi criado:** Invasores e funcionários desonestos que obtêm privilégios administrativos máximos (root ou domain admin) tentam limpar os logs de auditoria do sistema operacional para apagar as evidências de suas fraudes e escapar da justiça.

🛡️ **Visão do Auditor de GRC:** Em auditorias financeiras e forenses (SEC Rule 17a-4, Sarbanes-Oxley), o auditor exige armazenamento WORM (Write Once, Read Many), como buckets de nuvem configurados com Object Lock em modo Compliance, onde nem mesmo o administrador da conta consegue deletar os logs antes do prazo de retenção legal.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho do exame: 'Ensure audit logs cannot be modified or deleted, even by a rogue system administrator'. Resposta: Immutable logs / WORM (Write Once, Read Many) storage.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Usuário nega que autorizou uma transferência financeira milionária enviada por sua conta	**Não-repúdio (Non-repudiation via Assinatura Digital)**
Como é gerada uma assinatura digital para garantir a autoria de uma mensagem?	**Hash do arquivo cifrado com a Chave Privada do remetente**
Como o receptor valida que a assinatura digital recebida é legítima?	**Decifra a assinatura com a Chave Pública do remetente e compara o hash**
Comprovar que um contrato foi assinado antes de o certificado do signatário ser revogado	**Carimbo de Data/Hora Seguro (Secure Timestamping / TSA)**
Impedir que um administrador com privilégios de root delete registros de auditoria após invasão	**Armazenamento Imutável / WORM (Write Once, Read Many)**
Qual a diferença essencial entre uma função Hash e uma Assinatura Digital?	**Hash prova apenas Integridade; Assinatura Digital prova Integridade + Autoria + Não-repúdio**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um banco está projetando um sistema para clientes corporativos autorizarem transferências bancárias de alto valor online. O banco quer garantir que, após uma transferência ser enviada, o cliente não possa negar posteriormente tê-la autorizado. Qual controle o banco deve exigir para cada solicitação de transferência?

A) Uma assinatura digital RSA gerada com a chave privada do cliente e verificada com a chave pública do cliente

B) Criptografia da solicitação de transferência com a chave pública do banco

C) Um hash SHA-256 da solicitação de transferência armazenado no banco de dados do banco

D) Um segredo HMAC compartilhado gerado conjuntamente pelo banco e pelo cliente

QUESTÃO 2 · CENÁRIO DE EXAME

Uma plataforma de gestão de contratos recebe um acordo assinado eletronicamente. O destinatário precisa provar que a assinatura foi criada pelo remetente e que o remetente não pode negar tê-la assinado. Qual chave o destinatário deve usar para validar a assinatura?

A) Chave privada do destinatário

B) Chave pública do remetente

C) Chave privada do remetente

D) Chave privada da autoridade certificadora

QUESTÃO 3 · CENÁRIO DE EXAME

Dois departamentos compartilham uma chave HMAC simétrica para proteger entradas de log de auditoria. Durante uma disputa, um departamento afirma que o outro poderia ter modificado os logs porque ambos conhecem a mesma chave. Por que esse projeto de HMAC falha em fornecer não-repúdio?

A) HMAC não usa uma função hash

B) Qualquer departamento com a chave compartilhada poderia gerar um HMAC válido

C) HMAC criptografa os logs com uma chave privada

D) HMAC fornece confidencialidade, mas não integridade

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa de software distribui patches de segurança pela Internet. Os clientes precisam verificar que um patch realmente veio da empresa e que a empresa não pode negar posteriormente tê-lo publicado. O que a empresa deve fazer?

A) Assinar o hash do patch com a chave privada da empresa

B) Criptografar o patch com a chave pública de cada cliente

C) Publicar o hash do patch em um site HTTP

D) Comprimir o patch com uma senha compartilhada pelos clientes

QUESTÃO 5 · CENÁRIO DE EXAME

Um administrador altera uma regra de firewall e depois nega ter feito a alteração. O sistema de gestão de mudanças da organização registra cada alteração e exige que administradores usem credenciais criptográficas pessoais. Qual evidência melhor permitiria aos investigadores provar qual administrador autorizou a alteração?

A) Uma assinatura digital válida no registro de alteração verificada com a chave pública daquele administrador

B) Uma chave de sessão simétrica usada durante o login SSH do administrador

C) Um log de firewall mostrando o endereço IP de origem da estação de trabalho do administrador

D) Um hash de senha armazenado no serviço de diretório para o administrador

QUESTÃO 6 · CENÁRIO DE EXAME

Uma prestadora de saúde envia um relat��rio de auditoria a um regulador. O regulador exige garantia de que o relatório foi criado pelo diretor de conformidade da prestadora e que o diretor não pode alegar posteriormente que foi forjado. Qual operação criptográfica o diretor de conformidade deve realizar?

A) Criptografar o relatório com a chave pública do regulador

B) Gerar o hash do relatório e criptografar o hash com a chave privada do diretor de conformidade

C) Gerar o hash do relatório e armazenar o hash em um banco de dados local

D) Criptografar o relatório com uma chave simétrica compartilhada com o regulador

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa quer implementar assinaturas digitais para seus executivos, de modo que documentos de políticas assinados possam ser verificados por qualquer funcionário. Qual afirmação descreve o uso correto das chaves?

A) Executivos assinam com suas chaves públicas; funcionários verificam com chaves privadas

B) Executivos assinam com suas chaves privadas; funcionários verificam com as chaves públicas correspondentes

C) Executivos assinam com uma chave simétrica compartilhada; funcionários verificam com a mesma chave

D) Executivos assinam com a chave privada da CA; funcionários verificam com a chave pública da CA

QUESTÃO 8 · CENÁRIO DE EXAME

Um desenvolvedor envia código-fonte para um repositório. A gerência quer garantir que o desenvolvedor não possa negar posteriormente a autoria de um commit específico. Qual mecanismo deve ser habilitado?

A) Assinar cada commit com a chave privada do desenvolvedor

B) Criptografar cada commit com a chave pública do servidor de repositório

C) Exigir que o desenvolvedor use uma senha de equipe compartilhada para commits

D) Armazenar apenas o hash MD5 de cada commit no repositório

QUESTÃO 9 · CENÁRIO DE EXAME

Um fornecedor e um comprador finalizam um acordo de compra eletronicamente. Ambas as partes querem impedir que a outra negue posteriormente a concordância com os termos. Qual implementação melhor atende a esse requisito?

A) Ambas as partes assinam digitalmente o hash do acordo com suas próprias chaves privadas

B) Ambas as partes criptografam o acordo com uma chave AES compartilhada

C) O comprador gera o hash do acordo e envia o hash ao fornecedor

D) O fornecedor armazena o acordo em um servidor de arquivos somente leitura

QUESTÃO 10 · CENÁRIO DE EXAME

Um arquiteto de segurança implementa um controle em que cada corretor assina ordens de negociação com uma chave privada pessoal, e a plataforma as verifica com a chave pública do corretor. Qual propriedade de segurança esse controle fornece principalmente?

A) Não-repúdio

B) Confidencialidade

C) Disponibilidade

D) Ofuscação

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Uma assinatura digital RSA gerada com a chave privada do cliente e verificada com a chave pública do cliente

Correto: a assinatura digital com a chave privada do signatário fornece não-repúdio, pois somente o cliente possui a chave privada. Criptografar com a chave pública do banco fornece confidencialidade; hash sozinho fornece integridade, mas não origem/não-repúdio; HMAC compartilhado pode ser gerado por qualquer uma das partes, então é repudiável.

Questão 2: Alternativa B — Chave pública do remetente

Correto: assinaturas digitais são verificadas com a chave pública do signatário. A chave privada do remetente é secreta; a chave privada do destinatário é para descriptografia ou assinatura pelo destinatário; a chave privada da CA assina certificados, não o contrato.

Questão 3: Alternativa B — Qualquer departamento com a chave compartilhada poderia gerar um HMAC válido

Correto: com um segredo compartilhado, ambas as partes podem criar o MAC, então não se pode provar qual parte gerou. HMAC usa hash; não usa chave privada para criptografar; ele fornece integridade e autenticação simétrica, mas não não-repúdio.

Questão 4: Alternativa A — Assinar o hash do patch com a chave privada da empresa

Correto: assinatura de código ou assinatura digital com a chave privada da empresa fornece não-repúdio e permite verificação com a chave pública. Criptografia por cliente não prova origem; hash em HTTP pode ser alterado; senha compartilhada não prova origem.

Questão 5: Alternativa A — Uma assinatura digital válida no registro de alteração verificada com a chave pública daquele administrador

Correto: a assinatura digital vincula a identidade ao registro e fornece não-repúdio. Chave de sessão SSH é compartilhada ou efêmera; IP pode ser falsificado ou compartilhado; hash de senha autentica login, mas não assina o registro e pode ser usado por outro se comprometido.

Questão 6: Alternativa B — Gerar o hash do relatório e criptografar o hash com a chave privada do diretor de conformidade

Correto: assinar o hash com a chave privada é uma assinatura digital e fornece não-repúdio. Criptografia com chave pública do regulador dá confidencialidade; hash local não prova autoria; chave simétrica compartilhada é repudiável.

Questão 7: Alternativa B — Executivos assinam com suas chaves privadas; funcionários verificam com as chaves públicas correspondentes

Correto: a chave privada assina e a chave pública verifica. O inverso é inválido e inseguro; chave simétrica não fornece não-repúdio; a chave da CA assina certificados, não documentos, a menos que a própria CA seja a signatária.

Questão 8: Alternativa A — Assinar cada commit com a chave privada do desenvolvedor

Correto: assinatura de commit usa a chave privada do desenvolvedor e verifica com a chave pública; fornece não-repúdio. Criptografia para o servidor não prova autoria; senha compartilhada não é única; hash sozinho não identifica autor.

Questão 9: Alternativa A — Ambas as partes assinam digitalmente o hash do acordo com suas próprias chaves privadas

Correto: cada assinatura com chave privada fornece não-repúdio para cada parte. Chave AES compartilhada é repudiável; hash sozinho não assina; servidor somente leitura não prova concordância de ambas.

Questão 10: Alternativa A — Não-repúdio

Correto: não-repúdio impede negar a origem ou a ação. Confidencialidade protege contra divulgação; disponibilidade garante acesso; ofuscação oculta código. A assinatura digital com chave privada é o mecanismo usado aqui.